

HiveForce Labs

THREAT ADVISORY



ATTACK REPORT

Hiatus Hacking Campaign Targets DrayTek Vigor Routers to Steal Data

Date of Publication

March 07, 2023

Admiralty Code

A1

TA Number

TA2023120

Summary

First appeared: July 2022

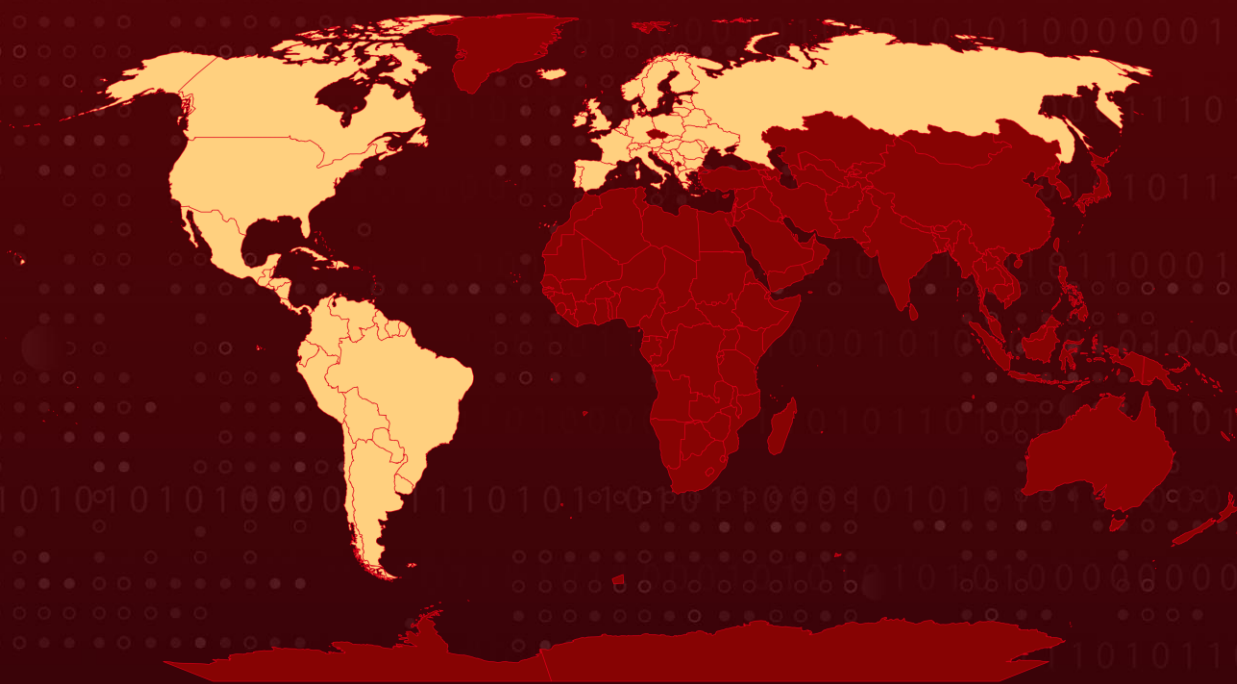
Attack Region: Europe, North America, and South America

Affected Product: DrayTek Vigor models 2960, 3900 running an i386 and ARM-based architecture

Malware: HiatusRAT

Attack: The Hiatus hacking campaign targets DrayTek Vigor routers to steal data and create a covert proxy network. The campaign uses a malicious script, HiatusRAT malware, and tcpdump to capture network traffic and pass command and control server traffic through a SOCKS5 proxy.

🗡️ Attack Regions



Powered by Bing
© Australian Bureau of Statistics, GeoNames, Microsoft, Navinfo, OpenStreetMap, TomTom, Zenrin

Attack Details

#1

A malware campaign called "Hiatus" that targets business-grade routers, specifically DrayTek Vigor models 2960 and 3900 running an i386 architecture. The campaign started in July 2022 and is ongoing, the campaign deploys two malicious binaries: HiatusRAT, a Remote Access Trojan, and a variant of tcpdump that enables packet capture.

#2

Once a system is infected, HiatusRAT allows the attacker to remotely interact with the system and use it as a covert proxy to monitor router traffic on ports associated with email and file-transfer communications. The packet-capture binary enables the attacker to capture data passing through the router. The initial access vector is currently unknown.

#3

The campaign appears to be focused on data collection and maintaining a minimal footprint to limit exposure. At least a hundred businesses have been infected, primarily in Europe, North America, and South America. The campaign's purpose is to steal sensitive information transmitted through the compromised router, such as email content, credentials, and uploaded and downloaded file content.

Recommendations



Security Leaders

Phishing simulations and routine education and awareness training and communications rarely account for MFA fatigue and web browser hygiene. Integrate and communicate all lessons learned.



Security Engineers

- **Uni5 Users:** This is an actionable threat advisory in HivePro Uni5. Prioritize and block all indicators attributed to the threat actors and attacks through your Command Center. Test your controls with Uni5's Breach & Attack Simulation.
- **All Engineers:** Refer to and action upon the 'Potential MITRE ATT&CK TTPs' & 'Indicators of Compromise (IoC)' on the following pages.

Potential MITRE ATT&CK TTPs

<u>TA0002</u> Execution	<u>TA0003</u> Persistence	<u>TA0004</u> Privilege Escalation	<u>TA0005</u> Defense Evasion
<u>TA0006</u> Credential Access	<u>TA0007</u> Discovery	<u>TA0009</u> Collection	<u>TA0011</u> Command and Control
<u>T1027</u> Obfuscated Files or Information	<u>T1113</u> Screen Capture	<u>T1059</u> Command and Scripting Interpreter	<u>T1204</u> User Execution
<u>T1204.002</u> Malicious File	<u>T1059.004</u> Unix Shell	<u>T1547</u> Boot or Logon Autostart Execution	<u>T1547.010</u> Port Monitors
<u>T1001</u> Data Obfuscation	<u>T1090</u> Proxy	<u>T1036</u> Masquerading	<u>T1040</u> Network Sniffing
<u>T1005</u> Data from Local System			

Indicators of Compromise (IOCs)

TYPE	VALUE
MD5	644fb8fb4f4ff8e7ff90fdb92357ef3
IPV4	66.42.108[.]185 46.8.113[.]227 104.250.48[.]192 149.248.0[.]203

TYPE	VALUE
SHA256	6eb7357c0492960150286418e2a2f18513f50e925630bf2e6235422143f2e6c6 6e21e42cfb93fc2ab77678b040dc673b88af31d78faf91700c7241337fc5db2 4877bdc4fa80ad8e38600d1e0f3e9fdfbce2a6658ba050347281842345c5dd5e 382d64d5943001a1df569f8ddae9490509ed96ba8128de6e74acff6d879d7035 36f6045fac9289df716ea9f3f657fd9c560660bfc70bebd0e07c1d42025f9a3a 27b957fe2c5e9f3c98cfae5e90a2cd90a9adb8c9ac9de21118a751d9679bc4af 193481c4e2cbd14a29090f500f88455e1394140b9c5857937f86d2b854b54f60 15960d2d7584ff90922e1c69f33c00508de4caa8b05a1341142b31f1661dd56f 07cc70b287cbcd13ef965c5a9815e1e2dcb7bfa4664beafdc7b57b5af3a8dd12
SHA1	da1cd4b75787d8c3079ca4b7709bf788e7e2021e cb01eb90c2c968a1d1e17136ba8609ff1eafb9eb c55a8c027482ce281903f4b6b0b370a6efc7252c a80c9729984976eeb6b20a48a5dae8b10e4dc724 5ec68cd73e3ca516b2518bc3307f5381bcc52b20 525c04e97a0e2b38243f11debec9e100cc51fb15 2a770ad9d8e34b71323f026dcbe6b70b67e415db 22ff6af7256397267d1919cbb78bfdcccb6e5e39 167ea14b961877bec689cf8714b450e55a8033bd



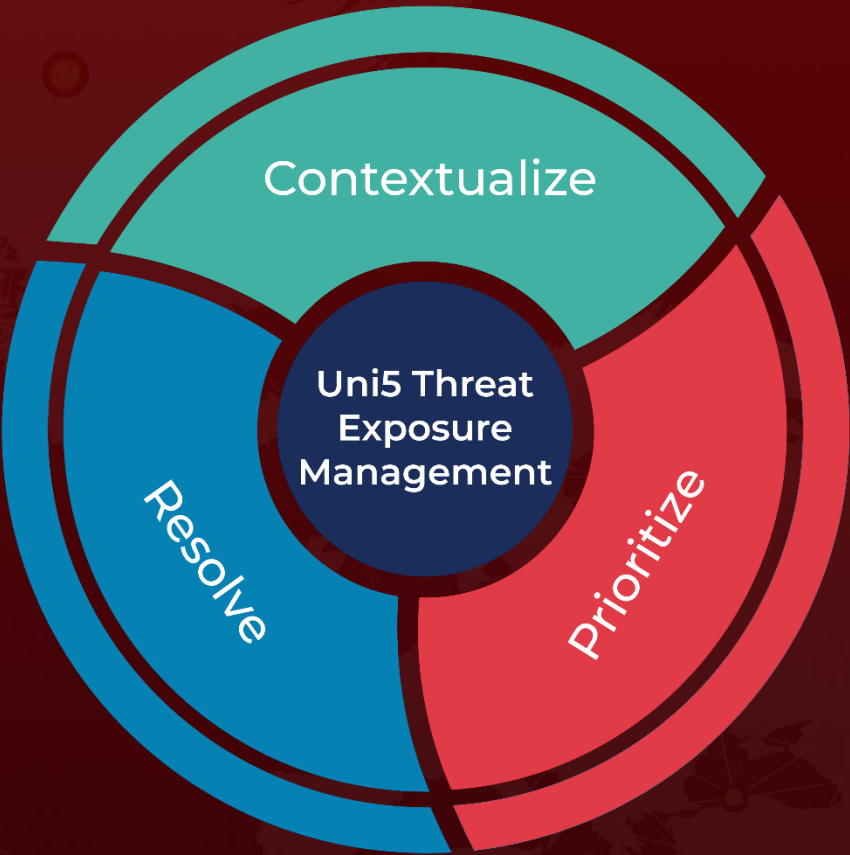
References

https://blog.lumen.com/new-hiatusrat-router-malware-covertly-spies-on-victims/?utm_source=press+release&utm_medium=referral

What Next?

At Hive Pro, it is our mission to detect the most likely threats to your organization and to help you prevent them from happening.

Book a free demo with HivePro Uni5: Threat Exposure Management Platform.



REPORT GENERATED ON
March 7, 2023 • 12:10 AM

© 2023 All Rights are Reserved by HivePro



More at www.hivepro.com